

PRATIK SANJAY KHAIRNAR

PENETRATION TESTER | VAPT ENGINEER

Nashik, Maharashtra, India | +91-8799981052 | pratik.khairnar.sec@gmail.com
linkedin.com/in/pratik-khairnar-sec | github.com/pratik-khairnar-sec

PROFESSIONAL SUMMARY

CEH v13 certified Junior Penetration Tester and final-year B.Tech (Cyber Security and Forensics) student with hands-on experience in web application and API penetration testing, vulnerability assessment and VAPT reporting using Burp Suite, aligned to OWASP Top 10 and OWASP API Security Top 10. Specialized in authentication and password-reset flaws (token predictability, host-header poisoning, session fixation, OTP/2FA bypass, IDOR/BOLA). Built AUTHENTIX v2.1.0, a Burp Suite extension in Java; write CVSS-scored reports with PoC and remediation. Seeking an entry-level VAPT Engineer / Penetration Tester role.

TECHNICAL SKILLS

Penetration Testing: VAPT, Web Application Penetration Testing, API Security Testing, Vulnerability Assessment, Manual and Automated Testing, Business Logic Flaws

Vulnerabilities and Standards: OWASP Top 10, OWASP API Security Top 10, OWASP ASVS, Broken Authentication, Broken Access Control, IDOR/BOLA, BFLA, SQL Injection (SQLi), Cross-Site Scripting (XSS), CSRF, CORS, JWT Attacks, Session Management, Password Reset Flaws, OTP/2FA Bypass, Account Takeover

Security Tools: Burp Suite (including extension development), Kali Linux, Nmap, Nessus, Metasploit, SQLMap, Ghauri, Nuclei, Subfinder, cURL, Postman

Programming and Development: Python (Selenium, Requests, Threading), Java (Burp Montoya API, Swing, JUnit 5, Gradle), Node.js, Bash, Git/GitHub, Telegram Bot API

Digital Forensics: OSINT, Malware Analysis (Android APK), Network Traffic Analysis, Chain of Custody, Incident Response, IOC Analysis

Networking and Reporting: HTTP/HTTPS, TCP/IP, DNS, TLS, Linux, Windows; CVSS Scoring, Proof of Concept (PoC), Risk Prioritization, Remediation Guidance, Technical Report Writing

PROFESSIONAL EXPERIENCE

Cyber Crime Intern | Cyber Police Station, Nashik Police Commissionerate Jan 2026 - May 2026

- Investigated 15+ live cybercrime cases using digital forensics for incident investigation and cyber fraud detection, maintaining strict chain of custody for digital evidence.
- Conducted network traffic analysis and OSINT to trace ownership of suspicious websites; performed malware analysis on Android APK evidence and documented IOCs for senior officers.

Junior Penetration Tester | GROOTT Services Jun 2025 - Oct 2025

- Performed manual web application penetration testing with Burp Suite to identify, validate and document OWASP Top 10 vulnerabilities, including broken authentication, broken access control and injection flaws.
- Tested login, password-reset and session-management workflows for logic flaws and token-handling weaknesses; delivered VAPT reports with CVSS-aligned risk ratings, PoC and remediation steps, and retested fixes before client delivery.

SECURITY PROJECTS

AUTHENTIX v2.1.0 - Authentication, IDOR/BOLA and Secret-Scanning Suite for Burp Suite 2026

Java 17/21, Burp Suite Montoya API, Swing, JUnit 5, Gradle | pratik-khairnar-sec.github.io/authentix-enterprise

- Built a Burp Suite extension that passively models login, OTP, session, password-reset and account-recovery flows as a per-actor state machine and checks them against 29 security invariants: OTP replay, session fixation, reset-token reuse, host-header reset poisoning, JWT algorithm confusion, refresh-token rotation, CSRF and account enumeration.
- Implemented a cross-actor IDOR/BOLA authorization matrix with BFLA detection, a SHA-256 fingerprinted token-lifecycle tracker (raw secrets never stored) and 28 secret and logic rules covering AWS, GCP, Azure, GitHub, Stripe, Firebase and AI API keys, hardcoded JWT secrets and client-side 2FA/RBAC bypasses.
- Developed an attack-path correlator that chains findings into 12 account-takeover and data-breach scenarios with PoC/cURL reproduction, Markdown export and asynchronous Telegram alerts.
- Validated with a passing JUnit 5 test suite (zero false positives on secure traffic) and a self-built vulnerable Node.js/Express banking lab, NimbusBank v2, with 16 exploitable challenge vectors confirmed via live HTTP requests.

Reflectra v7.0.0 - Context-Aware XSS Scanner Python, Selenium | github.com/pratik-khairnar-sec/Reflectra

- Confirms Cross-Site Scripting (XSS) through real headless-Chrome JavaScript dialog execution instead of string matching, prioritizing about 2,600 payloads by injection context; adds DOM-sink analysis, authenticated and blind XSS scanning, multi-threading and Telegram-delivered HTML reports.

BlindStrike v7.0.0 - Blind SQL Injection Testing Framework Python | github.com/pratik-khairnar-sec/BlindStrike

- Detects time-based (SLEEP, WAITFOR, pg_sleep) and boolean-based blind SQL injection across MySQL, MSSQL, PostgreSQL and Oracle with baseline measurement and confirmation retests; supports URL, POST body and header injection, multi-threaded scanning and JSON/CSV/HTML reports with Telegram alerts.

EDUCATION AND CERTIFICATIONS

Sandip University, Nashik 2023 - Present

B.Tech in Computer Science and Engineering, Specialisation in Cyber Security and Forensics (Final Year) | CGPA: 7.42/10

Certified Ethical Hacker (CEH v13) - EC-Council

July 2026

Cisco Certified Network Associate (CCNA) - Cisco

November 2025